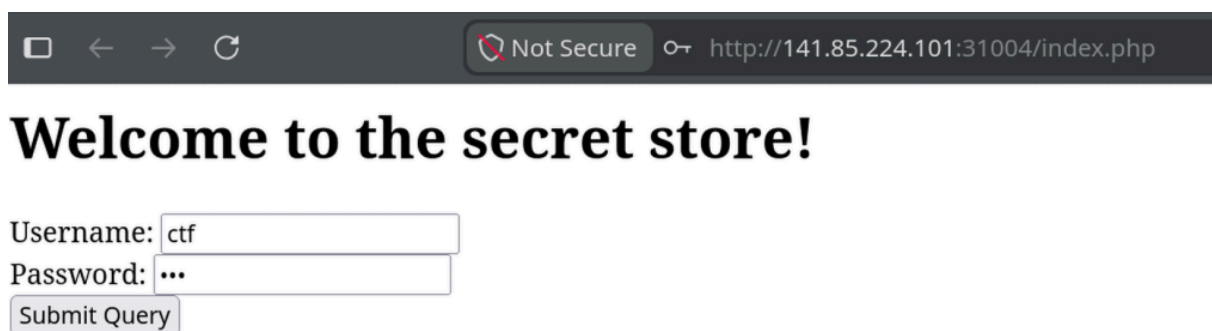


SSS Qualifiers v13 Write-Ups

Author: Dămureanu Cosmin-George

Track: Web Security

1. Sequel Pro

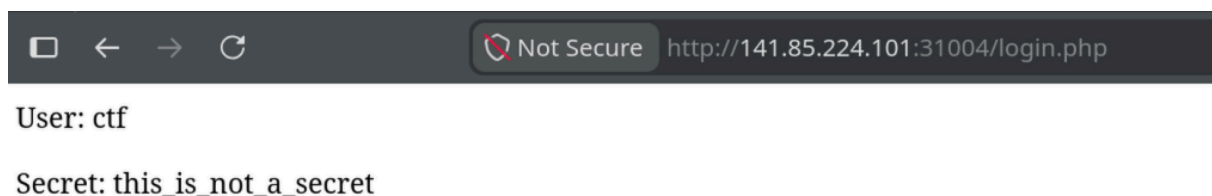


Username:

Password:

We get a simple login page and some credentials (**USER:** `ctf` ; **PASSWORD:** `ctf`)

By entering those credentials, we get:



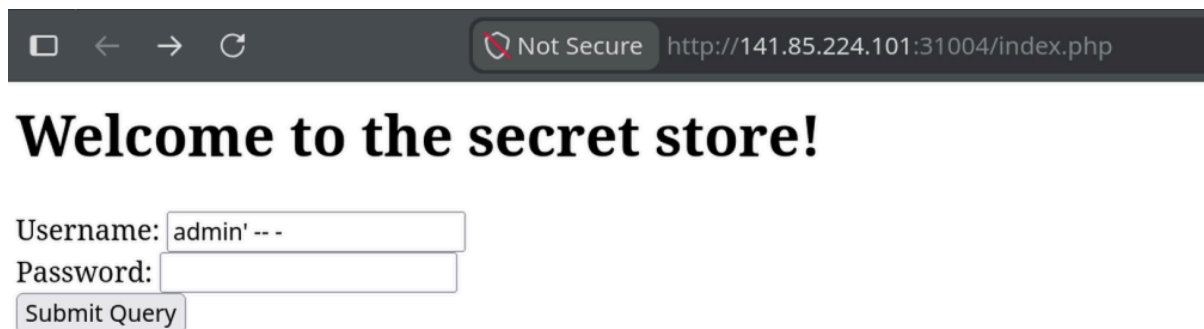
User: ctf

Secret: this_is_not_a_secret

This doesn't give us anything useful

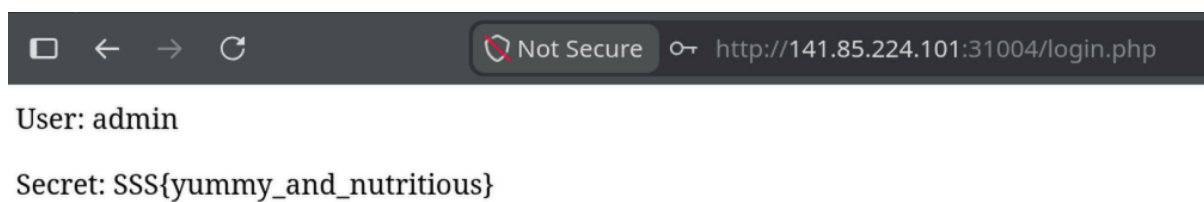
The name of the challenge (**Sequel Pro**) makes me think of **SQL injection**

A naive query would look like `[...] WHERE username = 'ctf' AND password = 'ctf'` . We can enter `admin' -- -` as username so that the query would be `WHERE username = 'admin' -- -' AND password = 'ctf'` , which would ignore the password and give us admin privileges.



Username:

Password:

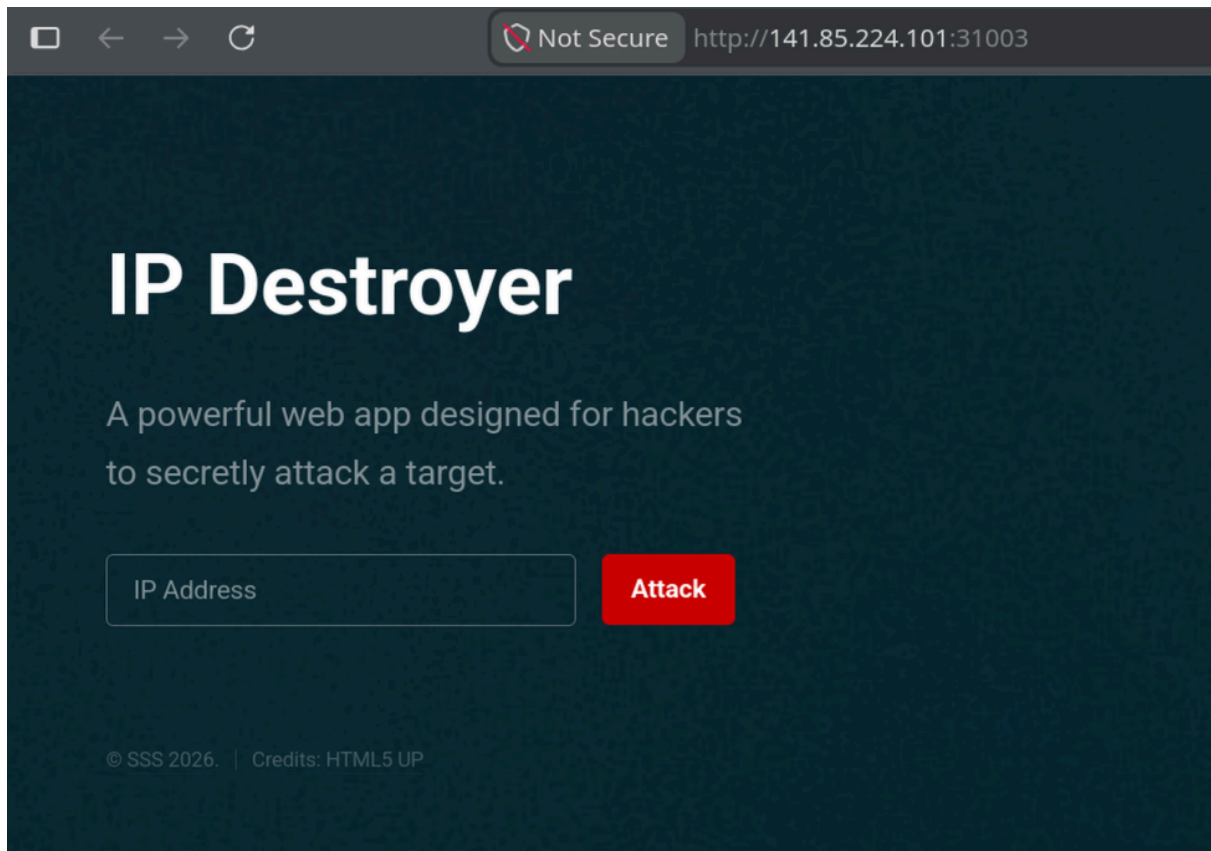


User: admin

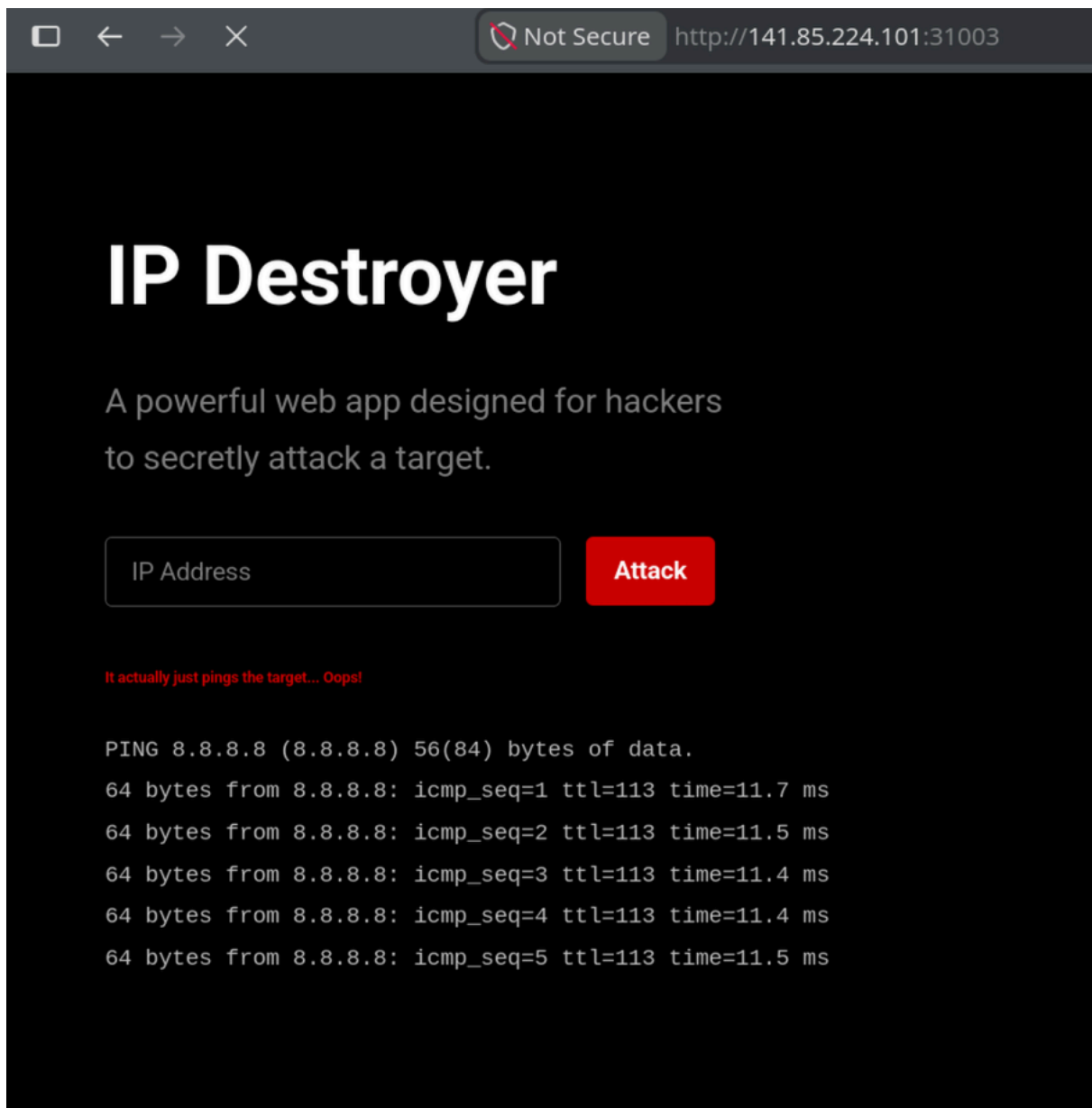
Secret: SSS{yummy_and_nutritious}

FLAG: `SSS{yummy_and_nutritious}`

2. IP Destroyer

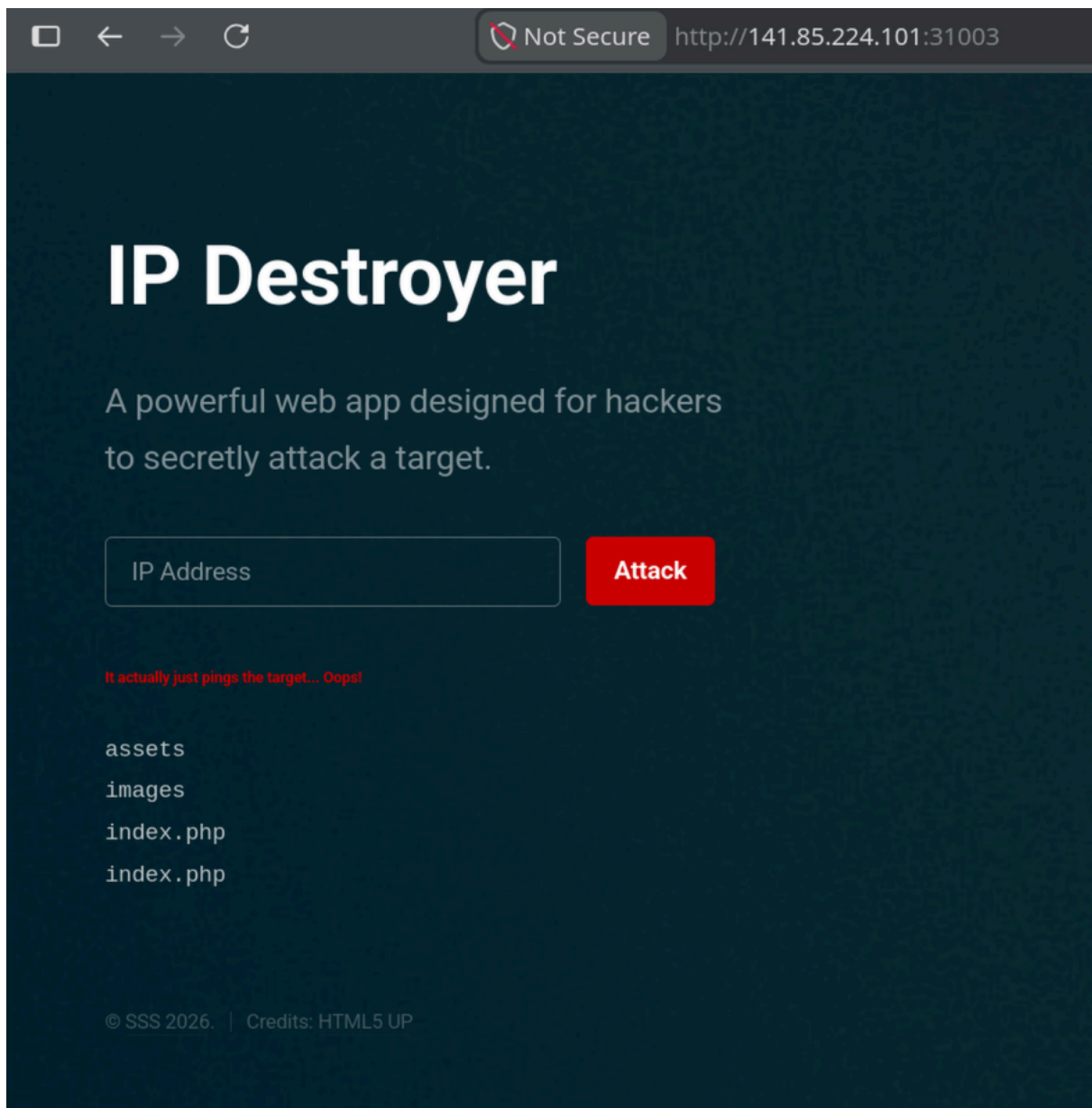


We get a page where we can enter IP addresses. By testing with a random IP address like `8.8.8.8` , we find out that it just prints the output of a ping used in a shell.

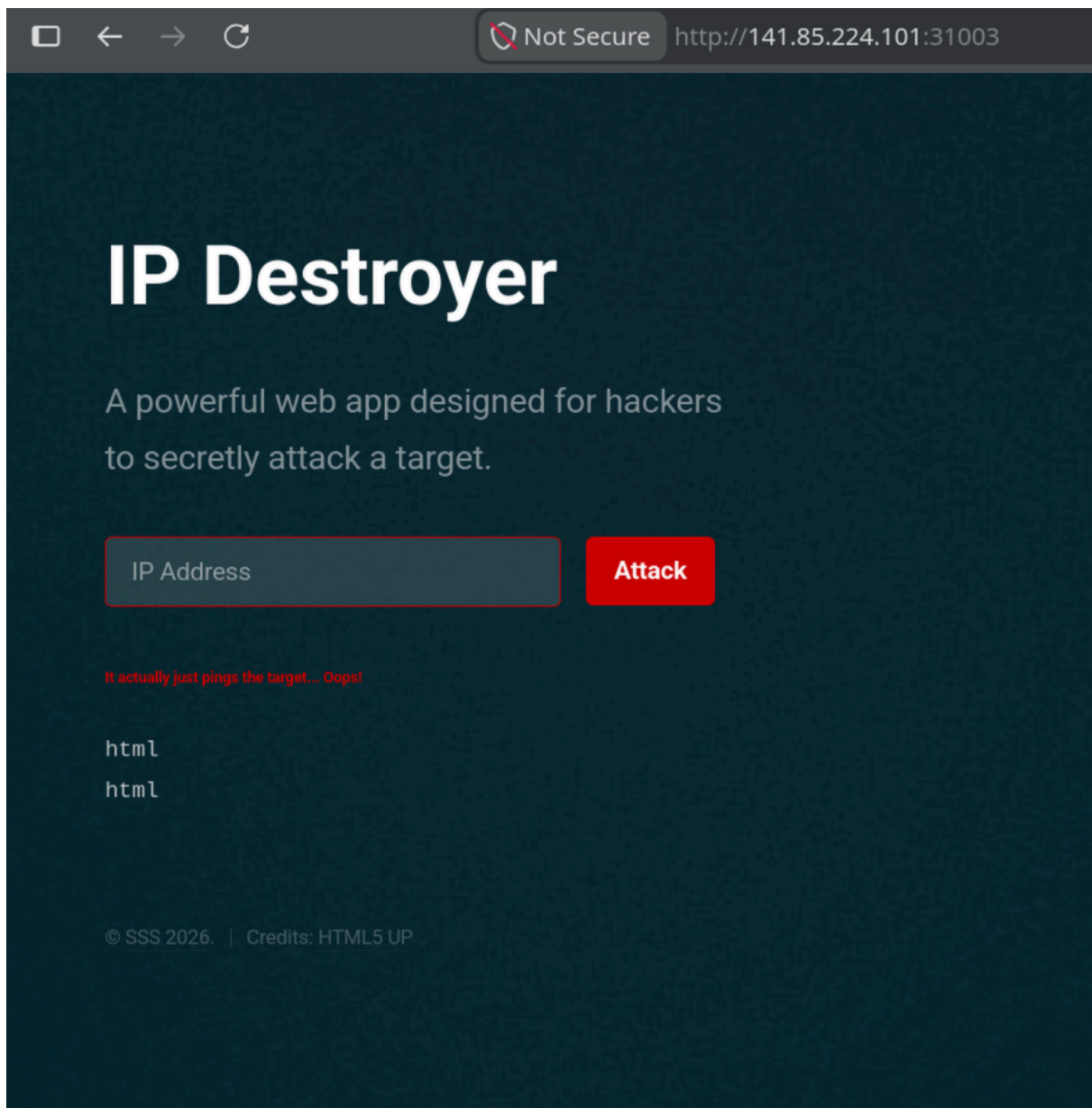


That makes me think of **command injection**

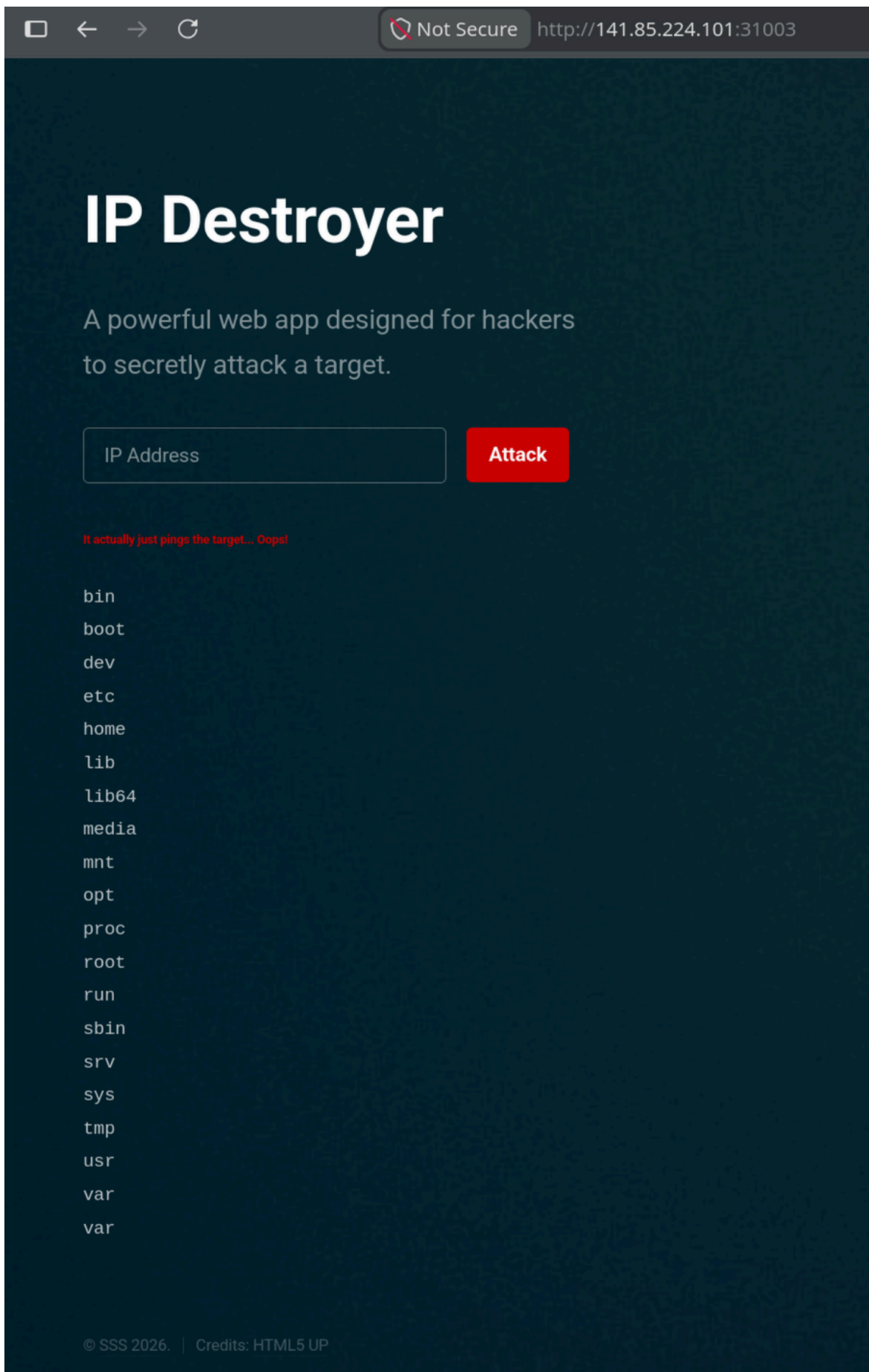
I'll put a `^C` after the IP address so that it would stop the process (CTRL+C), then a `; ls` to execute the `ls` command after that. It should look like `8.8.8.8 ^C; ls`



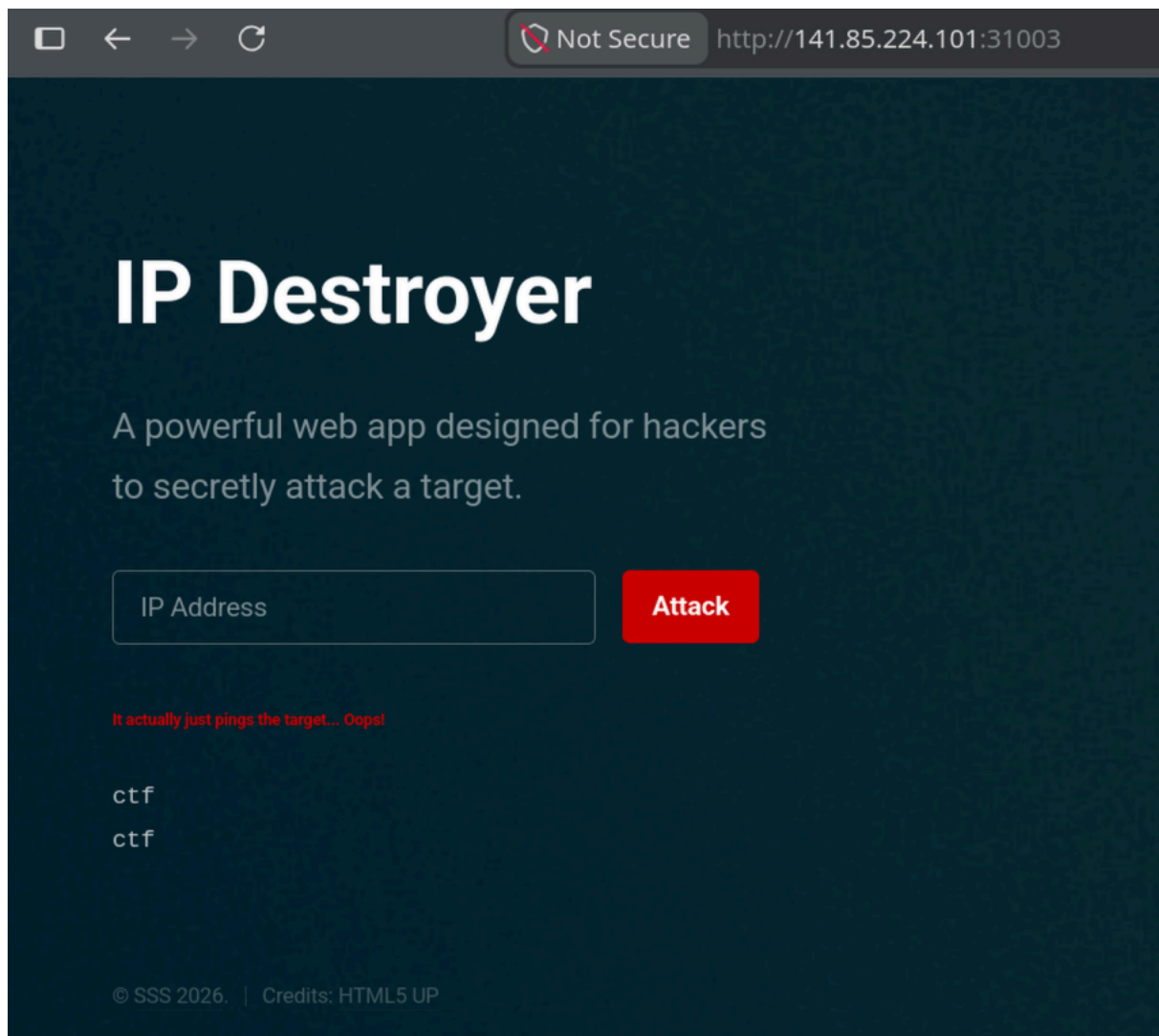
That isn't helpful. We'll try the parent directory: `8.8.8.8 ^C ; ls ..`



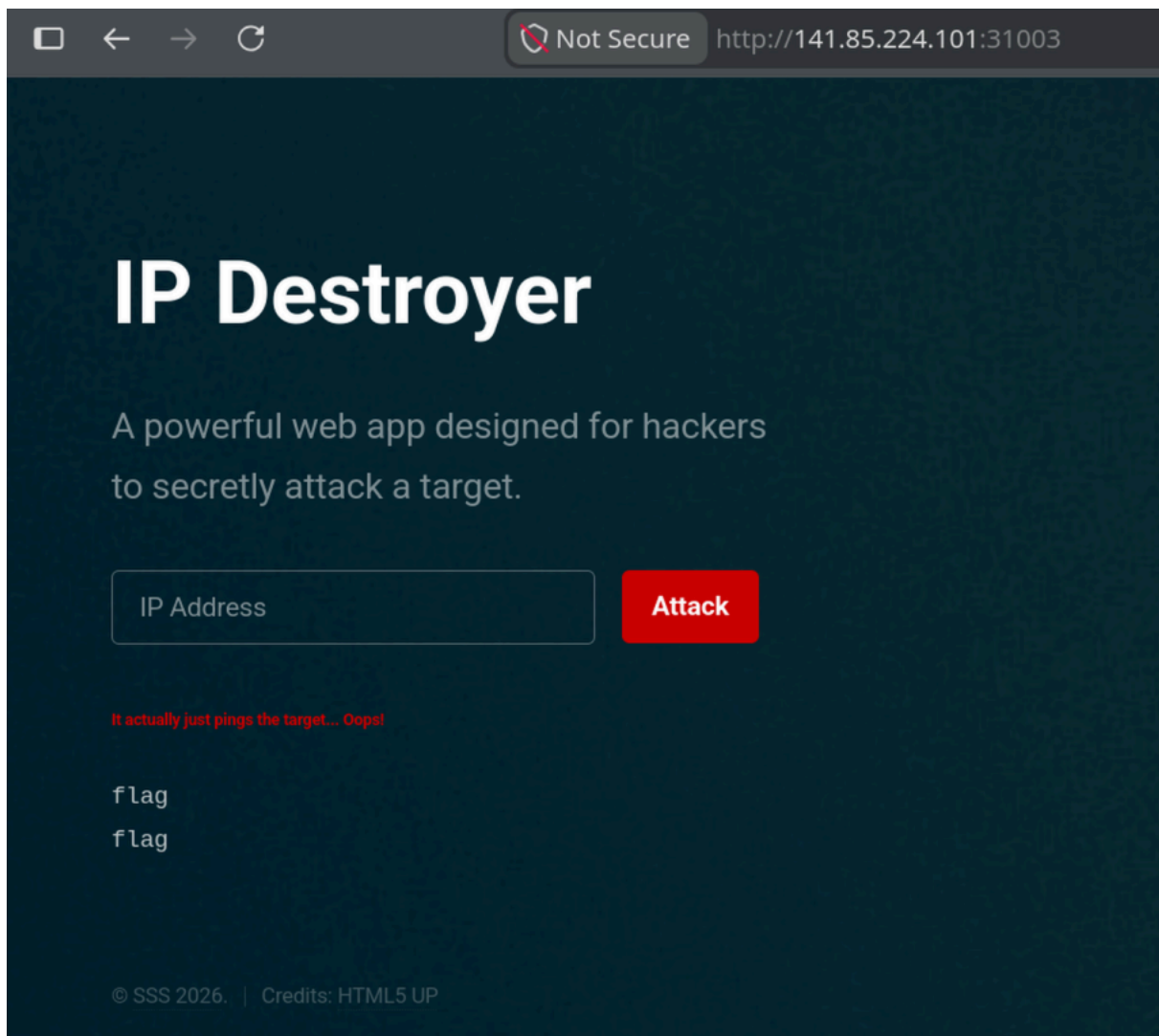
Still not useful. Let's try the root directory: `8.8.8.8 ^C ; ls /`



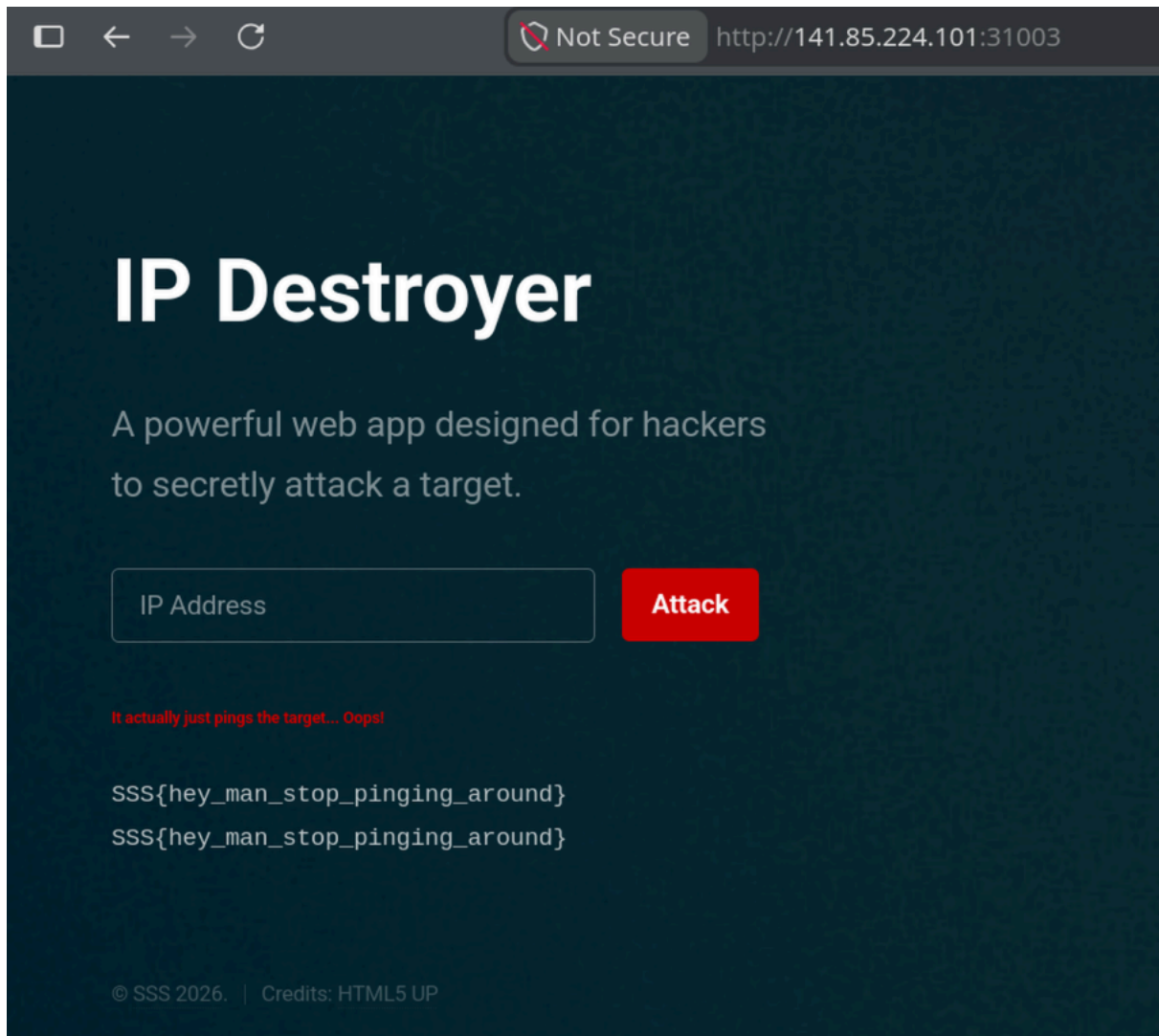
The flag we are looking for would most probably be hidden in `/home/` ,
so let's try `8.8.8.8 ^C ; ls /home/`



Looks like we're on the right path. We'll go deeper: `8.8.8.8 ^C ; ls /home/ctf/`



That should be it! We'll try to get it: `8.8.8.8 ^C ; cat /home/ctf/flag`



Flag: `SSS{hey_man_stop_pinging_around}`